

SIMATS ENGINEERING

COURSE NAME: CRYPTOGRAPHY AND NETWORK SECURITY

COURSE CODE: CSA5117

NAME: G. BALASUBRAMANIAN

REG.NO:192521001

DEPARTMENT: B.TECH. IT

ASSIGNMENT: C04 – AT3

FACULTY NAME: DR. R. DHARANI

1) Comparison of AH and ESP in IPSec

Feature	Authentication Header (AH)	Encapsulating Security Payload (ESP)
Authentication	Provides data-origin authentication	Provides data-origin authentication
Integrity	Provides integrity protection	Provides integrity protection
Confidentiality	✗ Not provided	✓ Provides encryption
Anti-replay protection	✓ Supported	✓ Supported
Encryption	✗ No	✓ Yes
Header protection	Protects payload and selected IP-header fields	Mainly protects the payload; does not protect the outer IP header
Performance overhead	Lower computational overhead because no encryption is performed	Higher overhead because encryption and authentication are performed
NAT compatibility	Poor — AH authenticates parts of the IP header, which NAT may modify	Better — commonly works with NAT using NAT-T
Typical use	Networks requiring integrity/authentication without confidentiality	VPNs, secure remote access, site-to-site communication

1. Security Services

AH provides:

- Data integrity
- Data-origin authentication
- Anti-replay protection
- Protection against modification of authenticated IP-header fields

However, AH does not encrypt data, so the actual contents remain visible.

ESP provides:

- **Confidentiality through encryption**
- **Data integrity**
- **Data-origin authentication**
- **Anti-replay protection**

Therefore, ESP offers a more comprehensive set of security services.

2. Performance Overhead

AH generally has lower processing overhead because it does not perform encryption. ESP requires encryption and usually authentication, so it consumes more CPU resources and may introduce additional processing delay.

However, with modern hardware acceleration for AES and other cryptographic algorithms, the performance difference is usually much less significant than it was historically.

3. Suitability for Different Network Scenarios

- **AH: Suitable when confidentiality is not required and the primary requirement is authentication and integrity.**
- **ESP: Suitable when sensitive information must be protected from eavesdropping, especially over untrusted networks.**
- **ESP with tunnel mode: Particularly suitable for site-to-site and remote-access VPNs because it can encrypt the entire original IP packet and encapsulate it inside a new IP packet.**

Which is more appropriate for VPN deployment?

ESP is the preferred choice for VPN deployment.

A VPN normally carries sensitive information across an untrusted network such as the Internet. Therefore, confidentiality is essential, not just authentication and integrity. ESP can encrypt the traffic while also providing integrity and authentication.

Conclusion:

Although AH has lower overhead and provides strong integrity and authentication, it cannot provide confidentiality and has compatibility problems with NAT. ESP provides a more complete security solution and is therefore more appropriate for modern IPSec VPNs, especially when used in tunnel mode with appropriate encryption and authentication algorithms.

2) Comparison of Transport Mode and Tunnel Mode in IPSec

IPSec provides two main operating modes: Transport Mode and Tunnel Mode. The major difference is how much of the original IP packet is protected and whether a new IP header is added.

Feature	Transport Mode	Tunnel Mode
Protection	Protects the IP payload and selected parts of the original IP packet	Protects the entire original IP packet
IP Header	Original IP header remains visible	Original IP header is encapsulated and protected
New IP Header	No	Yes
Overhead	Lower	Higher
Performance	Faster due to less processing and smaller packet size	Slightly slower due to additional encapsulation and encryption
Security	Provides good protection for the payload	Provides stronger protection because the original IP header is hidden
Typical use	Host-to-host communication	Network-to-network and VPN communication
Example	Two servers communicating securely	Two company networks connected through an Internet VPN

1. Transport Mode

In transport mode, IPSec protects the payload of the original IP packet while keeping the original IP header.

Structure:

Original IP Header → IPSec Header → Encrypted/Protected Payload

Advantages:

- Lower overhead
- Faster processing
- Suitable for direct host-to-host communication
- Requires less bandwidth

Disadvantage:

- The original source and destination IP addresses remain visible.

Example:

Two servers in different locations need to communicate securely. Transport mode can protect the data exchanged between the two hosts.

2. Tunnel Mode

In tunnel mode, the entire original IP packet—including its original IP header—is encapsulated inside a new IP packet.

Structure:

New IP Header → IPSec Header → Encrypted Original IP Header + Payload

Advantages:

- Protects the complete original IP packet
- Hides the original source and destination addresses from intermediate networks
- Provides stronger privacy
- Ideal for VPNs and communication between networks

Disadvantage:

- Greater computational and bandwidth overhead because of additional headers and encapsulation.

Host-to-Host vs Network-to-Network

Host-to-host communication → Transport Mode

Transport mode is generally more effective when two individual hosts need to communicate directly. It provides security while minimizing processing and packet overhead.

Network-to-network communication → Tunnel Mode

Tunnel mode is more effective for connecting entire networks through an insecure network such as the Internet. IPSec gateways can encrypt and encapsulate packets before sending them across the Internet.

Conclusion

Transport mode is best suited for host-to-host communication because it provides security with lower overhead. Tunnel mode is better suited for network-to-network communication and VPNs because it protects the entire original IP packet and hides internal network information.

Therefore, for a typical site-to-site IPSec VPN, tunnel mode is the preferred choice, while transport mode is appropriate when securing direct communication between individual hosts.

3)Comparative Analysis of PGP and S/MIME

PGP (Pretty Good Privacy) and S/MIME (Secure/Multipurpose Internet Mail Extensions) are both used to secure email through encryption, authentication, integrity, and digital signatures. However, they differ significantly in key management and trust models.

Feature	PGP	S/MIME
Key Management	Users generally generate and manage their own public/private key pairs	Uses digital certificates issued by a Certificate Authority (CA)
Trust Model	Decentralized Web of Trust	Hierarchical PKI-based trust model
Authentication	Users verify and sign each other's keys	Identity is verified through trusted CAs
Scalability	Can become difficult to manage in large organizations	Highly scalable with centralized certificate management
Certificate Management	No mandatory centralized certificate authority	Certificates can be centrally issued, renewed, revoked, and managed
Enterprise Integration	Requires additional configuration and user training	Strong integration with enterprise email systems
Ease of Use	More complex for ordinary users	Generally easier for users once PKI is configured
Interoperability	Depends on PGP-compatible software	Widely supported by enterprise email clients
Best suited for	Individuals, technical users, decentralized environments	Businesses and large organizations

1. Key Management

PGP:

Users typically generate their own key pairs and exchange public keys. Users are responsible for protecting their private keys and verifying the authenticity of other users' public keys.

S/MIME:

Each user receives a digital certificate containing their public key. The certificate is issued and signed by a trusted Certificate Authority (CA). Organizations can centrally manage certificates, including issuance, renewal, and revocation.

Advantage: S/MIME is generally easier to manage in a corporate environment.

2. Trust Models

PGP uses a Web of Trust. Users decide whether they trust a particular public key and can digitally sign other users' keys. This provides a decentralized trust model but can become complicated as the number of users increases.

S/MIME uses a hierarchical PKI trust model. A trusted CA establishes a chain of trust from the root CA through intermediate CAs to the user's certificate.

Thus, S/MIME provides a more centralized and administratively manageable trust structure.

3. Scalability

PGP can work well for small groups, but managing and verifying large numbers of keys becomes difficult as an organization grows.

S/MIME is more scalable because an organization can use centralized systems to:

- Issue certificates
- Renew certificates
- Revoke compromised certificates
- Maintain certificate policies
- Integrate certificates with corporate directories and email systems

4. Enterprise Usability

S/MIME is generally better suited for enterprises because it can integrate with common corporate email clients and centralized identity-management infrastructure.

PGP provides strong security but may require additional software, configuration, key exchanges, and employee training. This can increase the administrative burden.

Recommendation for a Corporate Email System

S/MIME is the recommended approach for most corporate email systems.

The main reasons are:

- 1. Centralized certificate management makes administration easier.**
- 2. PKI-based trust provides a clear and structured method for validating identities.**
- 3. Better scalability for large organizations.**
- 4. Enterprise email-client integration improves usability.**
- 5. Certificate revocation and renewal can be centrally controlled.**
- 6. It provides both encryption and digital signatures, protecting confidentiality, integrity, authentication, and non-repudiation.**

Final Evaluation

PGP is a strong choice when decentralized trust and user-controlled key management are important. However, for a large corporate email environment, the centralized management and PKI-based trust of S/MIME make it the more practical and scalable solution.

4) Comparison of Rule-Based and Machine Learning-Based Spam Detection

Email spam detection can be performed using rule-based techniques or machine learning (ML)-based techniques. Both approaches aim to identify unwanted emails, but they differ in how they recognize spam and adapt to new attack patterns.

Feature	Rule-Based Detection	Machine Learning-Based Detection
Working principle	Uses predefined rules and conditions	Learns patterns from training data
Examples	Block keywords, suspicious URLs, known senders	Naive Bayes, SVM, Random Forest, Neural Networks
Adaptability	Low	High
Handling new spam patterns	Poor unless rules are manually updated	Better at identifying previously unseen patterns
False positives	Can be high if rules are too strict	Can be reduced with proper training and tuning
Maintenance	Requires frequent manual rule updates	Requires periodic retraining/update of models
Processing overhead	Generally low	Higher than simple rule-based systems
Explainability	High; reason for blocking is clear	Varies; complex models can be difficult to explain
Scalability	Suitable for simple environments	Highly suitable for large-scale email systems
Best use	Known and predictable spam patterns	Dynamic and continuously evolving spam

1. Rule-Based Spam Detection

Rule-based systems identify spam using predefined conditions. For example:

- **Block emails from known spam addresses.**
- **Detect suspicious keywords such as "WIN MONEY".**
- **Block emails containing blacklisted URLs.**
- **Flag messages with suspicious attachments.**
- **Reject emails that fail specific authentication checks.**

Advantages:

- **Simple to implement.**
- **Fast processing.**
- **Easy to understand and audit.**
- **Effective against known spam patterns.**

Disadvantages:

- **Requires continuous manual updates.**
- **Easily bypassed when attackers modify wording or formatting.**
- **Strict rules can incorrectly classify legitimate emails as spam.**

2. Machine Learning-Based Spam Detection

ML-based systems learn characteristics of spam from previously classified emails.

Features can include:

- **Email text and keywords**
- **Sender information**
- **URL characteristics**
- **Email headers**
- **Attachment information**
- **Message structure and behavior**

Algorithms such as Naive Bayes, Support Vector Machines (SVM), Random Forest, and neural networks can be used.

Advantages:

- **Automatically learns spam patterns.**
- **Better at detecting variations of known spam.**
- **Can adapt to changing attacker techniques.**
- **Can achieve low false-positive rates when trained and tuned properly.**

Disadvantages:

- **Requires quality training data.**
- **Models need periodic retraining.**
- **More computationally expensive.**
- **Poor or biased training data can lead to incorrect classifications.**

Handling Evolving Spam Patterns

Rule-based systems:

They are less effective against evolving spam because attackers can easily change keywords, domains, formatting, or message structures. New rules must then be created manually.

ML-based systems:

They are generally more effective because they can learn from newly collected spam samples. For example, if attackers change the wording of phishing emails, an ML model can potentially identify other characteristics that remain similar.

Minimizing False Positives

False positives occur when a legitimate email is incorrectly classified as spam.

Rule-based systems can generate false positives when rules are overly broad. For example, blocking every email containing a particular word could accidentally block legitimate business communication.

ML systems can reduce false positives by considering multiple features simultaneously rather than relying on a single keyword. However, incorrect training data can also cause ML models to classify legitimate messages incorrectly.

A practical system can improve accuracy by combining:

- **ML classification**
- **Sender reputation**
- **Email authentication such as SPF, DKIM, and DMARC**
- **URL and attachment analysis**
- **User feedback**
- **Carefully designed rules**

Conclusion

Machine learning-based spam detection is generally more effective for modern email systems because spam patterns continuously evolve. Rule-based detection is fast and easy to interpret but requires frequent manual updates.

For a corporate email system, a hybrid approach is recommended: use rule-based filtering for known threats and policy enforcement, while using ML to detect new and evolving spam patterns. This combination provides better adaptability while helping minimize false positives.

5) Manual vs Automated Key Management in IPSec

IPSec requires Security Associations (SAs) and cryptographic keys to protect network communication. Keys can be configured manually or established automatically using protocols such as IKE (Internet Key Exchange).

Feature	Manual Key Management	Automated Key Management (IKE)
Key establishment	Administrator manually configures keys and IPSec parameters	IKE automatically negotiates keys and security parameters
Security	Secure if configured correctly, but keys are often long-lived	Stronger due to dynamic key generation and periodic rekeying
Scalability	Poor for large networks	Excellent for large networks
Key rotation	Manual	Automatic
Configuration effort	Very high	Relatively low after initial setup
Human error	High risk	Lower risk
Operational complexity	High as the number of devices increases	Lower and easier to automate
Failure recovery	Usually requires manual intervention	Can automatically renegotiate/re-establish SAs
Suitable for	Small, static networks or testing	Enterprise and large-scale networks

1. Manual Key Management

In manual key management, the administrator configures the same cryptographic keys and IPSec parameters on communicating devices.

For example, an administrator may manually configure:

- **Encryption algorithm**
- **Authentication algorithm**
- **Encryption keys**
- **Authentication keys**
- **Security Association parameters**

Advantages:

- **Simple for a very small network.**
- **Does not require an IKE infrastructure.**
- **Configuration is predictable and straightforward.**

Disadvantages:

- **Extremely difficult to maintain as the number of devices increases.**
- **Keys must be manually changed when they expire or are compromised.**
- **Human errors can result in incorrect or insecure configurations.**
- **Long-lived keys increase the impact of key compromise.**

2. Automated Key Management Using IKE

IKE automatically establishes and manages IPSec Security Associations. It allows communicating devices to authenticate each other, negotiate security algorithms, establish shared secret keys, and periodically rekey the connection.

This removes the need for administrators to manually configure individual session keys.

Advantages:

- **Automatic key generation and exchange.**
- **Supports periodic rekeying.**
- **Reduces administrator involvement.**
- **Provides authentication between peers.**
- **Scales well across large networks.**
- **Reduces configuration errors.**

Disadvantages:

- **More complex to configure initially.**
- **Requires correct authentication and policy configuration.**
- **Vulnerabilities or misconfigurations in the key-management infrastructure can affect security.**

Impact on Large Organizations

Security

Manual management:

Security depends heavily on administrators correctly configuring and protecting keys. If the same key remains in use for a long period, compromising that key can expose a large amount of traffic.

IKE:

Dynamic key establishment and regular rekeying improve security. Even if a particular session key is compromised, the exposure can be limited by the use of new keys for subsequent sessions.

Scalability

Manual key management becomes increasingly impractical as the number of VPN connections grows. If many devices need secure connections, administrators must configure and maintain numerous keys and SAs.

IKE is much more scalable because devices can automatically negotiate their SAs and keys.

Operational Complexity

Manual management creates significant administrative overhead. Every key change, device addition, or security-policy modification may require configuration on multiple devices.

IKE reduces this operational burden through automated negotiation and rekeying, although administrators still need to maintain authentication credentials, policies, and IKE configurations.

Conclusion

For a large organization, automated key management using IKE is clearly preferable.

- **Manual key management: Suitable for small, static networks, laboratories, or controlled environments.**
- **IKE: Suitable for enterprise VPNs, large networks, and environments requiring regular key rotation.**

Therefore, IKE provides better security, scalability, and operational efficiency, while manual key management becomes increasingly difficult and error-prone as the organization grows.